

GOVERNANCE_AUDIT_2026-08-08_ROUND2

Governance & Constitution Compliance Audit — Round 2 — 2026-08-08

Revision: 6 **Last modified:** 2026-08-09T12:54:30Z **Status:** active
Scope: Live re-verification of every item in docs/GOVERNANCE_AUDIT_2026-08-07.md (GA-01..27) and docs/REMAINING_WORK_PLAN.md (RW-01..21) against the current tree, PLUS a fresh gap scan of domains neither document covered, PLUS forensics on two anonymous “Auto-commit” commits that landed between the two audits. Assembled from 3 parallel read-only subagent audits + direct verification, 2026-08-08. No file was modified by this audit. Every finding cites file:line or real command output (§11.4.6 — no guessing).

Baseline: HEAD 743097a on main. GA-audit baseline was 0d05ec1; three more commits landed since, two of them more bare Auto-commit commits (9c8f684, 743097a) produced **during this very investigation**. Root cause narrowed (2026-08-08, systematic-debugging pass) — see RD2-00 Update.

Rev-6 addendum (2026-08-09T12:54:30Z) — RD2-22 + RD2-23 CLOSED, live-verified: - RD2-22 (P0 auth gap) — CLOSED. Live curl-verify completed on the running qbittorrent-proxy container for both routes, in both states (default-open per §11.4.122, and hardened once BOBA_API_TOKEN is configured): - **Default (env unset, no auth header):** PATCH /api/v1/schedules/{id} → HTTP 404 ({“detail”:“Schedule not found”} — reached the handler, never 401/500); PUT /api/v1/theme → HTTP 200 (theme persisted and echoed back). Confirms the §11.4.122 no-auth default is preserved. - **Hardened (.env backed up to .env.rd2-23-backup, BOBA_API_TOKEN set, ./start.sh --recreate, container healthy ~65s later):** PATCH ../schedules/{id} — no token → 401; wrong Authorization: Bearer token → 401; correct token → 404 (auth passed, schedule genuinely absent). PUT /theme — no token → 401; wrong token → 401; correct token via X-Boba-Token → 200

({"paletteId":"nord","mode":"light","updatedAt":"2026-08-09T12:51:11.665275+00:00"}
All 6 assertions matched expectations exactly; one transient client-side timeout (curl exit 28, host under concurrent-agent load — podman stats showed the container briefly at 104% CPU, uptime load average 14+) was retried successfully, not a defect. -
Restoration verified: .env restored from the backup (diff before restore showed only the BOBA_API_TOKEN line differed), ./start.sh --recreate re-run, container healthy, then re-confirmed default-open: PUT /theme (no token) → 200, PATCH /schedules/{id} (no token) → 404 — the default no-auth contract is back in effect, BOBA_API_TOKEN back to its original commented-out line. - Full tests/contract/+tests/unit/ regression sweep from the prior session remains a background concern tracked separately (RD2-00-class interruption); the RD2-22 fix itself is now source+test+artifact+runtime verified per §11.4.108 and is CLOSED. - **RD2-23 (P1, §11.4.135 regression guard + HelixQA Challenge) — CLOSED.** Regression guard: tests/security/test_hooks_schedules_auth.py's existing TestMutatingRoutesTokenGate (already parametrized over both routes since the RD2-22 GREEN commit) IS the standing guard — no duplicate test authored. §11.4.115 polarity-switch proof captured this session: with Depends(require_api_token) commented out of scheduler.py::update_schedule and routes.py::put_theme, python -m pytest tests/security/test_hooks_schedules_auth.py -k "PATCH or PUT" → **4 failed, 4 passed** (test_no_token_is_401_when_token_set and test_wrong_token_is_401_when_token_set RED for both routes, each "expected 401 ... got 200" — the right reason, auth bypassed). Restoring the Depends(...) calls returned the full suite to **31 passed** with zero source diff against the fixed code. HelixQA Challenge bank: added BOBA-PRX-009 (PATCH /api/v1/schedules/{id}) and BOBA-PRX-010 (PUT /api/v1/theme) to submodules/helixqa/banks/boba-download-proxy.yaml, following the existing BOBA-PRX-NNN schema, each exercising both the default-open and hardened states plus wrong-token rejection against the real running stack (not mocked); the exact curl commands in the bank's steps[] were the same commands live-verified above. - **RD2-00 Update 2 (2026-08-08, confirmed): root cause is a second live session, not a rogue process.** A parallel Claude session (Opus 5, same +0500 host) independently landed constitution commit 177f2b0 (new anchor §11.4.238) while this session was mid-edit on the identical anchor number — a live, observed collision, resolved per §11.4.227(B) by deferring to the already-published version (this session's unpublished duplicate was never pushed anywhere, confirmed via git branch -r --contains across all 8 remotes before discarding). This **downgrades RD2-00's severity band:** the mechanism is not an unidentified external actor, it is (most likely) the operator's own second session/device, still bypassing per-commit TDD/review discipline on ITS side, but not a security-incident-class unknown. RD2-10..13 remain open (still needs a proper commit/review discipline on whichever session produces these) but the URGENCY is now P1, not P0. - **RD2-40 [P0]:**

§11.4.238 compliance — MECHANISM STOOD UP AND EXERCISED, 2026-08-08. docs/QA_DISCOVERY_LEDGER.md created with the discovery-channel schema, seeded with 4 real entries from this session's own findings (RD2-22, RD2-41a, RD2-41b, BOB-008), each with a real coverage-escape audit citing the specific missing/blind check, and 3 of the 4 already closed with a genuine new automated check carrying real RED→GREEN evidence (the 4th, BOB-008's diff-check gap, was closed in the same session — see below). CLAUDE.md Critical Constraints now points at the ledger + states the discovery-channel-split mandate.

Closed-loop example fully exercised end-to-end: scripts/pre_build_verification.sh invariant 17 extended to run workable-items diff (not just validate) — RED-captured via tests/unit/test_pre_build_workable_items_diff_check.sh's §1.1 paired mutation (desynced docs/Issues.md correctly triggers a diff-specific FAIL, distinguished from the pre-existing unrelated BOB-009/010 validate issue so the test isn't a tautology), GREEN after the fix.

Honest boundary, stated explicitly (§11.4.6), not silently closed: full retroactive audit of every one of the ~50 GA-NN/RD2-NN findings in this document (each needs its own escape-audit entry) was NOT attempted — the ledger is honest that it starts now (100% out-of-band in its own tracked split table) rather than backfilling a false complete history. BOB-009/BOB-010's evidence_path gap remains open (no workable-items subcommand exists to fix a historical closure's evidence_path — see Root Cause 2 / RD2-19) and is NOT yet caught by any automated check (it's a validate-internal issue already surfaced by validate itself, so technically already “automated-caught” going forward, just not yet fixable via the tool). **Priority: downgraded from P0-blocking to P1-ongoing** — the zero-grace-period clause is about the MECHANISM existing and being applied to NEW findings going forward, which is now true; the remaining work (retroactive audit of historical findings, closing BOB-009/010) is incremental, not a release blocker in itself. - **NEW — RD2-41 [P1]:** scripts/docs_chain.sh (**FIXED this session**) and scripts/pre_build_verification.sh invariant 17 (**FIXED this session**) both hardcoded a non-existent bin/workable-items path, silently no-op'ing/skipping their DB-export and DB-validate steps on every run — root-caused and fixed via the same resolution chain already proven in constitution/scripts/reporting/report_item.sh (env override → committed constitution copy → on-demand go build). Regression guards: tests/unit/test_docs_chain_binary_resolution.sh (RED→GREEN verified) + tests/unit/test_pre_build_workable_items_invariant.sh (RED→GREEN verified). A SEPARATE, still-open defect surfaced while fixing this: pre_build_verification.sh's earlier “pre-code-review” mutation-marker scan aborts the ENTIRE script (exit 1) before invariant 17 is ever reached, on carrier false-positives — legitimate constitution/**/*_mutation_test.sh + *_test.go files that intentionally contain the literal strings MUTATE D/# MUTATION as part of their OWN §1.1 testing logic (verified

36 hits, all under constitution/scripts/{gates, multitrack,workable-items}/, all self-referential test/gate files, none genuine residue) — the exact §11.4.201 carrier-false-positive class already found twice this session (GA-24's guard-forbidden-commands.sh on constitution/docs/scripts/guard-forbidden-commands.md, and this session's own "sudo"-substring block on an unrelated echo string). Practical impact: the ENTIRE pre-build gate has not completed a full run for as long as this false-positive has been live** — no invariant past the mutation-marker check (including the just-fixed 17 and 18) has been genuinely enforced. Not fixed this session (real scope-creep risk after already fixing two root causes) — needs the marker-scanner to exclude self-referential test/gate files (or use a more structural check than a bare substring match), matching the fix direction already scoped for GA-24/RD2-01. **Priority: P1**, arguably should be P0 given it silently defeats the entire pre-build gate — flagged for the next work session.

RD2-00 — CRITICAL: unattributed, unreviewed "Auto-commit" mechanism actively pushing to main

This is the single most urgent finding in this document — more urgent than any individual security gap below, because it is an ACTIVE, ONGOING process, not a static defect.

- **Evidence:** Three commits at HEAD carry the bare message "Auto-commit" with no body, no ticket reference, no TDD trail: 54e313f (26 files, 2026-08-08T11:18:51+03:00), 9c8f684 (6 files, 2026-08-08T16:18:21+05:00), 743097a (2 files, 2026-08-08T16:25:52+05:00). The latter two landed **while this audit was in progress** — confirmed by re-running git log mid-investigation and finding new commits that were not present at session start.
- **Source unidentified, ruled out exhaustively:** no crontab entry (crontab -l → none), no systemd user/system timer or service referencing boba/commit/auto, no running process on this host (ps -ef) matching a commit loop, no script anywhere in the tree (grep -rn "Auto-commit" across .sh/.py/.js/.ts) that emits that literal string, no core.hooksPath configured, no PostToolUse/Stop hook in .claude/settings.json (only a PreToolUse guard). The **timezone on the two newest commits (+0500) does not match this host's own current timezone (+0300 MSK, hostname nezha)** — proving the commits originate from a different host or session with push access to the same GitHub remotes, not this machine. Per

§11.4.6, this is recorded as **UNKNOWN — external source, not reproducible from this host**, not guessed at.

- **RD2-00 Update (2026-08-08, systematic-debugging root-cause pass):** git reflog on this host proves 9c8f684 and 743097a were **never committed here** — they arrived via HEAD@{2026-08-08 14:26:30 +0300}: pull: Fast-forward, i.e. authored + pushed on the +0500 host, then simply fast-forwarded into this clone by an ordinary git pull. CronList confirms zero scheduled cloud agents visible to this session. Critically, the reflog also shows this project **already has an established, named cross-host sync pattern** from 2026-06-28: 55b8671/cdb555f — pull --rebase origin main (start/finish) wrapping commits explicitly titled "sync: post-rsync commit 20260628" and "sync: auto-commit before cross-host sync 20260628". The bare "Auto-commit" commits are almost certainly the *same* mechanism (rsync between this host and a second machine — CONTINUATION.md's own Session-13 notes reference a macOS host mounting /Volumes/T7), just invoked with a less-descriptive commit message than the June instance. **This narrows RD2-00 from "unknown process" to "a known-but-under-labeled operational sync script running on a second host this session cannot reach or inspect."** Root cause is now at the boundary of what's discoverable without operator input: which second host, is the sync script itself intentional-but-needs-a-real-message-and-review-gate, or is it a leftover/misconfigured job that should be retired. **Surfaced as OPERATOR-DECISION, not auto-executed** — the operator knows which other machine(s) hold push credentials to this repo; this session does not and should not guess (§11.4.6/§11.4.101).
- **Why this is severity-critical regardless of source:** every commit produced by this mechanism bypasses §2 (mandated commit wrapper, never raw git commit), §11.4.43 (TDD-fix discipline), §11.4.92 (5-pass evaluation), §11.4.125/§11.4.142/§11.4.194/§11.4.209 (mandatory independent Fable-xhigh code review before any commit — **no exception, ever**), and §11.4.234 (dedicated hook-validation script). It has already, in substance, silently applied fixes for GA-18, GA-21, GA-22, GA-25, GA-26, GA-27 (all verified correct in outcome — see below) alongside a docs/workable_items.db binary rewrite with **no corresponding docs/Issues.md/Fixed.md update** (a live §11.4.106(F) write-seam violation — see RD2-38). A mechanism that is *usually* correct is not evidence it is *safe*: the next unreviewed auto-commit could just as easily push a broken security change, a corrupted DB, or a secret.
- **Fix: (1) OPERATOR:** confirm which second host runs the rsync/sync job identified in the Update above, and whether it is the intended, sanctioned mechanism (in which case: give it a descriptive commit message matching the June precedent, and — since it already has push access — wire it through the §11.4.234-mandated dedicated commit/push script with real

validation stages instead of a raw `git add -A && commit && push`) or a stale/misconfigured job that should be retired; (2) until resolved, treat every future bare “Auto-commit” commit as an incident — do not assume its contents are safe without the same live re-verification this document performed.

- **Priority: P0 — investigate before anything else in this plan, independent of severity ranking below, because it can silently invalidate any other item’s “done” status at any moment.**
-

Part A — Corrections to GOVERNANCE_AUDIT_2026-08-07.md (GA-01..27), live-reverified 2026-08-08

Verdict legend: **DONE** (fully closed, live-evidenced) · **DONE-BUT-PROCESS-VIOLATION** (outcome correct, but landed via RD2-00’s anonymous mechanism with zero TDD/review trail — the *code* is fine, the *governance* is not, and both need separate remediation) · **PARTIAL** · **NOT-DONE** · **OPERATOR-DECISION-STILL-OPEN**.

Toolchain (GA-01..03)

- **GA-01 (python venv/toolchain) — DONE.** `.venv/` now exists (created 2026-08-08T00:09, pinned interpreter). Live-verified: `.venv/bin/python -m pytest tests/unit/ --co -q → 4340 tests collected in 5.21s, zero collection errors` (previously crashed with `ModuleNotFoundError: rpbs.rpbs`). Toolchain genuinely unblocked. (*A full run, not just collection, is still owed — fold into RD2-34.*)
- **GA-02 (frontend Vitest) — DONE.** `frontend/node_modules` reinstalled (368 entries, 365M, mtime 2026-08-08). `@angular/core@21.2.9`, `vitest@4.1.8` both match declared ranges.
- **GA-03 (extension Vitest) — DONE.** `extension/node_modules` now populated (was completely absent at audit time).

Governance/tracking seam (GA-04..10)

- **GA-04 (CONTINUATION.md staleness) — NOT-DONE.** Still Revision: 19, Last modified: 2026-06-16T23:55:00Z, “Session 14” — now **~53 days / 24+ commits** behind HEAD, one commit worse than when the first audit found it. Every commit since (including the RD2-00 auto-commits) is unreflected.
- **GA-05 (Lava porting items untracked) — NOT-DONE.** `grep -in "lava\|B0B-06[4-7]" docs/Issues.md docs/Fixed.md → zero hits`. Still no tracked workable item for the four implemented-in-code Lava findings.

- **GA-06 (PORTING-FROM-LAVA.md revision header) — DONE.** `**Revision:** 1 / **Last modified:** 2026-07-01T16:18:43Z` present (predates this round; the original audit's citation was already stale by the time it was read, or this landed between the two audits — either way, the header requirement is now satisfied).
- **GA-07 (README doc-link section) — DONE (structure), row-completeness unverified.** `### Tracked-Items + Status` Documents heading now exists at README.md:112 (added in 54e313f, +25 lines). **Not independently re-verified this round whether every mandated doc (CONTINUATION.md, Issues.md, Fixed.md, PORTING-FROM-LAVA.md, both new GA/RD2 audit docs, every Status.md/Status_Summary.md pair) actually has a row** — fold a completeness check into RD2-35.
- **GA-08 (browser_extension Status.md staleness) — NOT-DONE.** No evidence found that this file changed; not touched by any commit since the original audit.
- **GA-09 (workable_items.db BOB-008 operator_block_details row) — DONE.** Re-ran `workable-items validate --db docs/workable_items.db` — BOB-008 no longer appears in the violation list (only BOB-009/BOB-010, a **different, newly-surfaced** defect — see RD2-19).
- **GA-10 (no top-level v1.0.0 readiness ledger) — NOT-DONE.** Only docs/RELEASE_READINESS_20260616.html/.md/.pdf (dated point-in-time snapshot) and the extension's own ledger exist; no top-level proxy/merge-service ledger created.

Security corrections (GA-11..13) — plus original RW-01/03/04 P0 re-verification

- **RW-01 (hooks endpoint auth + sandboxing) — DONE, confirmed independently this round.** `download-proxy/src/api/hooks.py:112,168` — both `create_hook/delete_hook` carry `Depends(require_api_token)`. Real, attributed fix commit 37a8c45 (“fix(security): P0 hardening — SSRF block, hook sandbox, consistent auth, Go CORS”) predates both audits — this was done properly, with a real commit message, not via RD2-00.
- **RW-03 (SSRF guard) — DONE, confirmed independently this round.** `download-proxy/src/api/routes.py:997-1039` — real `ipaddress.ip_address(...).is_private / is_loopback` checks covering RFC-1918/loopback/link-local/169.254.169.254, same 37a8c45 commit.
 - **Multi-word query note:** not audited further; SSRF guard's presence and correctness should still get a dedicated live-container probe as part of RD2-34 (source-confirmed only).
- **RW-04 (magnet auth / Go CORS / Jackett admin) — DONE (magnet + CORS), Jackett admin unverified.** / `magnet route (routes.py:1368-1371)` carries `Depends(require_api_token)`. `qBitTorrent-go/internal/middleware/cors.go` has a real allowlist mechanism explicitly commented

“RW-04 fix” (never emits * + credentials). Jackett AdminPassword_set value in config/jackett/Jackett/ServerConfig.json not read this round — fold into RD2-34.

- **GA-11 (PATCH schedules / PUT theme still unauthenticated) — NOT-DONE. Real, live P0 security gap, unchanged since the first audit.** download-proxy/src/api/scheduler.py:108-109 (PATCH /{schedule_id}) and download-proxy/src/api/routes.py:82-83 (PUT /theme) both have **zero** Depends(require_api_token) — confirmed by direct reading, contrasted against sibling routes in the same files that DO have it. tests/security/test_hooks_schedules_auth.py:195-200’s _MUTATING enumeration is unchanged (still only 4 entries, missing both). Neither RD2-00 auto-commit touched these files.
- **GA-12 (rutracker ReDoS deployed) — DONE (source), runtime unverified.** plugins/rutracker.py:140 confirmed {0,512}/{0,256}-bounded. No live container stack running on this host at investigation time (podman ps shows only unrelated containers) — deploy-and-verify step still owed (RD2-34).
- **GA-13 (nmmclub SKIP-on-404 fallback) — NOT-DONE.** tests/e2e/test_live_stack_evidence.py:265 still contains the skip. Unchanged.

Test-type integrity (GA-14..18)

- **GA-14 (tests/integration/test_merge_api.py mocks SearchOrchestrator) — NOT-DONE.** 12× @patch("api.routes._get_orchestrator") still present; no real-service sibling added.
- **GA-15 (tests/e2e/test_full_pipeline.py mocks SearchOrchestrator) — NOT-DONE.** Same pattern, unchanged.
- **GA-16 (tests/contract/test_tracker_stats_contract.py mocks SearchOrchestrator) — NOT-DONE.** Same pattern, unchanged.
- **GA-17 (#legacy-untriaged tags never triaged) — CLOSED 2026-08-09 (RD2-33).** All 14 sites individually triaged with git-history evidence; see RD2-33’s Closed note under “Ungrouped remaining items” for the full per-site table.
- **GA-18 (7 dead jackett-autoconfig test bodies) — DONE-BUT-PROCESS-VIOLATION.** All correctly removed (one file deleted entirely, three others’ skip-only bodies stripped, replacement coverage pointers to the Go package preserved) — but landed anonymously inside 54e313f bundled with 25 unrelated files, not “one dedicated commit citing the git-history/migration evidence” as GA-18 explicitly demanded.

Go parity / stress-chaos (GA-19..20)

- **GA-19 (Go --profile go parity) — OPERATOR-DECISION-STILL-OPEN.** Confirmed unchanged: zero time.Ticker anywhere in qBitTorrent-go, no enricher package, zero exec.Command fan-out. Surfaced only, not auto-executed, per §11.4.66.
- **GA-20 (RW-14/15/16 stress/chaos) — NOT-DONE / PARTIAL.** No test_tracker_fetch_stress_chaos.py or test_scheduler_hooks_sse_stress_chaos.py exists. tests/stress/ has 9 real files but none covers the download-proxy tracker-fetch-with-cookie path or the Go scheduler+hooks+SSE-broker triangle (grep -rl "sse_broker\|SSEBroker\|hooks" tests/stress/*.py → zero hits). jackett_db_test.go:440-500 remains concurrency-only, no fault injection, predates the RW plan (commit 8936545, unchanged since).

Challenges/HelixQA + CONST-033 + gate scoping + Hard Stop #3 (GA-21..27)

- **GA-21 (jackett_autoconfig_clean_slate.sh retired endpoint) — DONE-BUT-PROCESS-VIOLATION.** challenges/scripts/jackett_autoconfig_clean_slate.sh now correctly polls the Go :7189 /api/v1/jackett/autoconfig/runs API with a header comment citing “GA-21, 2026-08-08”. Landed inside the anonymous 54e313f.
- **GA-22 (HelixQA bank dangling symlinks) — DONE-BUT-PROCESS-VIOLATION.** All 6 challenges/helixqa-banks/*.yaml are now relative symlinks (../../submodules/helixqa/banks/...) and every one resolves. Same anonymous commit.
- **GA-23 (HelixQA bank hardcoded /Volumes/T7/...) — NOT-DONE.** grep -rn "/Volumes/T7" submodules/helixqa/banks/*.yaml → still 20 hits. Neither auto-commit touched this submodule’s content.
- **GA-24 (no_suspend_calls_challenge.sh carrier false-positive) — PARTIAL, and a NEW instance of the same defect class was introduced in the same commit that fixed the old one.** scripts/host-power-management/check-no-suspend-calls.sh:65 now excludes constitution/docs/scripts/guard-forbidden-commands.md (fixed, correctly). But **the live script still FAILs today:** docs/incidents/2026-08-07-const033-poweroff-signal-triage.md (a NEW file added in the SAME 54e313f commit) quotes forbidden power-management verbs in its own prose (lines 106-108, 178-179) and is not in EXCLUDE_PATHS — a fresh carrier false-positive on a file that did not exist when the original exclusion list was written. This session independently reproduced the SAME false-positive class firsthand (see RD2-01 below) — this is not a one-off, it is a structural weakness in the guard’s substring-matching approach.
- **GA-25 (CONST-033 real-signal triage) — DONE-BUT-PROCESS-VIOLATION (content excellent).** docs/incidents/

2026-08-07-const033-poweroff-signal-triage.md (230 lines) fully satisfies the mandated triage sequence (uptime cross-check, kernel suspend-signal grep, OOM-kill grep, both CONST-033 challenges re-run with real output pasted, root-cause identified as a genuine orderly human-initiated poweroff — correctly ruled NOT a CONST-033 violation). Content quality is not in question; only the anonymous-commit process is.

- **GA-26 (ruff sweeping submodules/containers/) — DONE-BUT-PROCESS-VIOLATION.** pyproject.toml:89 now has `extend-exclude = ["submodules", "constitution", ".worktrees", ".venv"]`. Live-verified: `ruff check .` → **“All checks passed!” — 0 violations, confirmed true boba-only count.**
 - **GA-27 (Hard Stop #3 — start.sh subcommands) — DONE-BUT-PROCESS-VIOLATION, and untested.** start.sh’s `reload_python()` (lines 697-717), `reload_plugins()` (726-741), and `recreate_stack()` (750-763) are real, non-stub implementations exactly matching CLAUDE.md’s documented behaviour (clear `__pycache__` via `exec + restart`; restart-only with an explicit “run install-plugin.sh first” warning; real down && up). `bash -n start.sh` is syntax-clean. **But** `grep -rln "reload_python|reload_plugins|recreate_stack" tests/ challenges/` → **zero hits** — shipped with no test-first coverage at all, a direct §11.4.224 violation on top of the commit-hygiene one.
-

Part B — Fresh gap scan (domains not covered by GA-01..27 or RW-01..21)

RD2-01 — The project’s own guard-forbidden-commands.sh hook has a live, reproducible

substring carrier false-positive (self-demonstrated this session)

- **Evidence:** during this investigation, the command `echo "=== systemd system-level (may need no sudo for list) ==="` was **blocked** by the PreToolUse hook with `BLOCKED – §6.U no-sudo`, because the guard does a substring match for `sudo` against the ENTIRE command line, including inside an unrelated echo string (“need no **sudo** for list”). This is the exact §11.4.201 carrier-false-positive class GA-24 already documented for a different file — now independently reproduced live, proving it is a structural pattern in the guard’s matching approach, not a one-off content gap.
- **Fix:** the guard needs word-boundary / shell-token-aware matching (or restrict the sudo/su check to actual command-invocation position) rather than an unanchored substring grep across the whole line, mirroring the fix direction already scoped for GA-24 (`EXCLUDE_PATHS` is a band-aid per-file; the root cause is the matching strategy itself).

- **Priority: P2** (annoying, self-correcting via retry, but a real false-positive class that will keep recurring on new content).

RD2-02 — docker-compose.quality.yml: 8/8 services violate the project's own mandatory

container-hygiene corollary

- **Evidence:** CLAUDE.md's CONST-033 Operational Note states, verbatim: "*Container hygiene corollary (mandatory for every new compose service): mem_limit, pids_limit, and oom_score_adj: 500.*" docker-compose.yml's 5 services all correctly carry all three fields (verified). docker-compose.quality.yml's 8 services (sonarqube, sonar-db, snyk, semgrep, trivy, gitleaks, prometheus, grafana) have **zero** of the three fields on **any** service — including two restart: unless-stopped long-running services (sonarqube JVM, sonar-db postgres, prometheus, grafana) that could consume unbounded host memory under pressure, precisely the failure mode CONST-033 exists to prevent.
- **Fix:** add mem_limit/pids_limit/oom_score_adj: 500 to every service in docker-compose.quality.yml, sized appropriately per service (JVM/postgres need more headroom than the scanner CLIs).
- **Priority: P1** (mitigated only by this file being profile-gated, not started by default — still a real host-safety gap the moment an operator runs the quality stack).
- **Closed (2026-08-09, RD2-35):** all 8 services (sonarqube, sonar-db, snyk, semgrep, trivy, gitleaks, prometheus, grafana) now carry mem_limit/pids_limit/oom_score_adj: 500, following the boba-jackett reference pattern in docker-compose.yml. Sized per-service by real workload (not one cargo-culted value): sonarqube 4g/1024 (bundled JVM + embedded Elasticsearch + compute engine, the heaviest service — SonarQube's own docs recommend ≥ 2 GiB); sonar-db 1g/256 (single-tenant postgres); semgrep 2g/512 (full-repo AST matching across many rules — the heaviest one-shot scanner); snyk/trivy/prometheus 1g/256 each; gitleaks 512m/128 (lightest — regex-only secret scan); grafana 512m/256 (dashboard UI, no local TSDB). docker-compose.yml (the live product stack) was NOT touched. Verified valid with
podman-compose -f docker-compose.quality.yml config (with every profile enabled) — all 8 services resolve cleanly with the three fields present; docker-compose.yml's own boba-jackett service, network topology, and running containers were unaffected (no live-stack coordination needed, per this file's profiles:-gated, not-started-by-default design).

RD2-03 — docs/workable_items.db: machine-caught SSoT integrity violations + 90% of closures

have zero audit trail

- **Evidence:** constitution/scripts/workable-items/bin/workable-items validate --db docs/workable_items.db exits 1 with **2 real violations**: BOB-009 and BOB-010 both have a closure evidence_path that “does not resolve (narrative or multi-value text in a single-path field)”. Beyond the tool’s own catch, a direct SQL sweep shows **56 of 62 closed items (90%) have zero rows in item_history** and **all 62 closed items have empty closure_criteria and commit_ref columns** — the constitution names this DB the authoritative SSoT for closure audit trails (§11.4.93/§11.4.148(D4)/§11.4.226), but the trail exists only in git history for the overwhelming majority of items, not in the DB itself.
- **Fix:** (1) fix BOB-009/BOB-010’s evidence_path values via the workable-items tool’s proper update path (never raw SQL); (2) for the 56 audit-trail-empty closures, backfill item_history rows from git log where recoverable, and explicitly mark genuinely-unrecoverable ones (§11.4.6 — UNKNOWN rather than fabricated); (3) wire the docs_chain sync (see RD2-04) so future closures never land without a trail.
- **Priority: P1.**

RD2-04 — docs/workable_items.db and docs/Issues.md/Fixed.md have drifted

- **Evidence:** workable-items diff --db docs/workable_items.db --issues docs/Issues.md --fixed docs/Fixed.md → ~ **BOB-008 body differs (md=703 bytes db=576 bytes)**. Root cause: 54e313f rewrote the DB (file grew 135168→229376 bytes, two new BOB-008 item_history rows dated 2026-08-08) but did **not** touch docs/Issues.md/Fixed.md in the same commit — a live §11.4.106(F) write-seam violation (the mandated commit-time doc/DB sync hook did not fire, or doesn’t exist).
- **Fix:** reconcile BOB-008’s body between DB and MD via the workable-items tool (sync or md-to-db/db-to-md as appropriate — determine which side is authoritative for this specific drift), then verify/wire the commit-seam sync hook per §11.4.106(F) so this class of drift is prevented mechanically, not just fixed once.
- **Priority: P1** (composes directly with RD2-00 — this drift is a direct symptom of the unattributed-commit problem).

RD2-05 — docs/TOKENS_AND_KEYS.md documents 3 non-existent env-var behaviours and omits 1 real one

- **Evidence:** spot-check of 6 documented “optional metadata enrichment” env vars against download-proxy/src/merge_service/enricher.py:
 - TMDB_API_KEY — real, used (enricher.py:73,165,172). Correct.
 - OMDB_API_KEY — real, used (enricher.py:72,102,135), **but missing from the doc’s own § 4 table entirely** despite being the first metadata source tried.
 - TVDB_API_KEY — documented, **never read anywhere**; TVMaze (keyless) is the actual source.
 - MUSICBRAINZ_USER_AGENT — documented with a specific default embedding the operator’s own handle; **never read**, and the actual MusicBrainz call (enricher.py:280) sends no User-Agent header at all. The doc describes a configuration knob that does not exist in code.
 - ANIDB_CLIENT — documented, never read (AniList GraphQL used instead, keyless).
 - OPENLIBRARY_USER_AGENT — documented, never read.
- **Fix:** remove the 3 fictional vars from the doc (or implement the described behaviour if it’s actually wanted — operator decision), add the missing OMDB_API_KEY row.
- **Priority: P2.**
- **Closed (2026-08-09, RD2-37):** docs/TOKENS_AND_KEYS.md § 4 table corrected. Removed TVDB_API_KEY, MUSICBRAINZ_USER_AGENT, OPENLIBRARY_USER_AGENT (confirmed zero hits: `grep -rn 'TVDB\|MUSICBRAINZ_USER_AGENT\|OPENLIBRARY_USER_AGENT' download-proxy/qBitTorrent-go/ .env.example` returns nothing outside this doc; `enricher.py:_lookup_tvmaze/_lookup_musicbrainz/_lookup_openlibrary` read no env var at all). Corrected ANIDB_CLIENT (no AniDB integration exists) to the real ANILIST_CLIENT_ID (enricher.py:74,225-228, .env.example:236). Added the missing OMDB_API_KEY row (enricher.py:72,102,133-135). Note: this evidence block itself names 4 never-read vars, not 3 — the “3” in the Fix line above undercounted; all 4 were corrected/removed for accuracy rather than leaving one fictional entry standing to match the stated count. Revision bumped to 2.

RD2-06 — .trivyignore.yaml contains placeholder, non-real CVE IDs

- **Evidence:** two entries with literal placeholder IDs CVE-2025-XXXX-0001 / CVE-2025-XXXX-0002 that match no real vulnerability — template boilerplate never filled in. tests/unit/test_scanner_configs.py (the only covering test) validates structural well-formedness only, never that CVE IDs are real, and never enforces the expiry-date convention the file’s own header comment promises via a referenced test (tests/unit/

test_scan_config.py) that **does not exist anywhere in the repo under that name**. A green scanner-config test is masking non-functional CVE suppressions.

- **Fix:** replace the placeholders with real CVE IDs (or delete the entries if they were never real), then either author the promised test_scan_config.py expiry-enforcement test or correct the header comment to stop referencing a nonexistent test.
- **Priority: P2.**
- **Closed (2026-08-09, RD2-38):** deleted both placeholder entries — no real CVE recoverable (git log --follow -- .trivyignore.yaml shows one commit e3bebb6, never touched again, no linked issue; a live trivy image python:3.12-alpine scan run in this session found **zero** musl-libc or busybox findings, only 5 unrelated pip CVEs — confirming the placeholders never mapped to a real, currently-detectable finding). .trivyignore.yaml now ignores: []. Authored tests/unit/test_scan_config.py (the exact promised filename) with a genuine RED→GREEN TDD cycle: run against the pre-fix file it FAILED 2/4 (missing-expiry + placeholder-CVE-id checks); after the fix all 4 PASS; a temporary backdated entry (expires: 2020-01-01) was then injected to prove the expiry check independently FAILs, then removed and reconfirmed GREEN (4/4). Also corrected the two other dangling promises of a differently-named nonexistent test (.trivyignore's header comment, docs/SECURITY.md § Waiver policy which had promised tests/unit/test_scan_waivers_have_expiry.py) to point at the real, now-existing tests/unit/test_scan_config.py. docs/SECURITY.md revision bumped to 2.

RD2-07 — DDoS-class testing is fully absent from the mandated test-type matrix

- **Evidence:** tests/ has 18 subdirectories covering unit/integration/e2e/security/chaos/ stress/performance/benchmark/UI (13 of the constitution's ~14 mandated categories present). tests/load/locustfile.py covers throughput/scale only. **No file anywhere mentions DDoS, flood, or attack-resilience testing** — a distinct mandated category per §11.4.27, and not legitimately N/A given this is an internet-facing FastAPI/Gin service with public HTTP endpoints reachable over a LAN tunnel.
- **Fix:** author tests/ddos/ (or extend tests/load/) with rate-limit-enforcement, malformed-request-flood, and resource-exhaustion-under-attack coverage for the exposed download-proxy/merge-service endpoints.
- **Priority: P2.**

RD2-08 — docs/features/Status.md and docs/codegraph/Status.md are stale (same root cause

as GA-04/GA-08, different files, not previously tracked)

- **Evidence:** docs/features/Status.md — Revision: 7, Last modified: 2026-06-16T23:30:00Z — same ~2-month staleness class as CONTINUATION.md. docs/codegraph/Status.md — Revision: 1, 2026-06-06T14:40:00Z — even further behind.
- **Fix:** fold into the same remediation pass as GA-04/GA-08 (RD2-35) since they share the exact root cause: the doc-sync mechanism was not invoked after the recent commit wave.
- **Priority: P1** (same class as the already-P0-adjacent GA-04).

RD2-09 — submodules/jackett fork 1 commit behind upstream (informational)

- **Evidence:** git submodule status + fetch shows submodules/jackett 1 commit behind origin/master (e12342eb4, a trivial false-positive fix). All other submodules (constitution, challenges, containers, helixqa) are exactly at their upstream tip.
 - **Fix:** bump when convenient; not blocking anything.
 - **Priority: P3.**
-

Part C — Merged, root-cause-grouped remediation plan

The 40+ individual findings above cluster into **6 root causes**. Fixing the root cause closes multiple line items at once; fixing symptoms one-by-one (as the anonymous auto-commits partially did) does not.

Root Cause 1 — An unreviewed, unattributed commit mechanism is bypassing every governance gate

Closes: RD2-00 (and prevents recurrence of the “DONE-BUT-PROCESS-VIOLATION” pattern across GA-18/21/22/25/26/27).

1. **RD2-10 [P0, OPERATOR-DECISION]** Root-caused as far as this host allows (see RD2-00 Update): relog proves the two newest commits arrived via plain pull: Fast-forward from a +0500 host, matching this project’s own established 2026-06-28 cross-host rsync-sync pattern (cdb555f/55b8671). **Needs operator input to go further** — which second host

runs it, and is it the intended mechanism (just needs a real message + review gate) or a stale job to retire. Not auto-executed (§11.4.6/§11.4.101 — this session cannot inspect or guess at a host it has no access to).

2. **RD2-11 [P0]** Once identified: either wire it through a real §11.4.234 dedicated commit/push script (with the hook-validation stages this project already has via `.claude/settings.json`'s `PreToolUse` guard, extended to a real pre-commit content check) or shut it down if it serves no purpose.
3. **RD2-12 [P1]** Retroactively give proper, attributed, reviewed commit messages / history notes to the technically-correct changes it already made (GA-18, GA-21, GA-22, GA-25, GA-26, GA-27) — this can be a documentation/changelog note rather than a history rewrite (§11.4.113 — never rewrite published history), citing the git-history evidence per §11.4.124's investigate-before-attribute pattern.
4. **RD2-13 [P1]** Retroactively run the mandatory independent Fable-xhigh code review (§11.4.125/§11.4.142/§11.4.209) against the substantive diffs it introduced (`start.sh`'s three new functions especially, since they have zero test coverage — see Root Cause 4) — even though the changes already landed, a post-hoc review closes the governance gap and will surface RD2-27 (GA-27's missing tests) if not already caught.

Verification: no new bare “Auto-commit” commit lands after RD2-11; `git log` audited weekly until confirmed stable; the retroactive review (RD2-13) produces either a clean GO or a remediation item for each finding.

Root Cause 2 — The mandated tracking chain (CONTINUATION → Issues/Fixed/DB → README) has been

silently disconnected since 2026-06-16 **Closes: GA-04, GA-05, GA-08, GA-10, RD2-04, RD2-08, and prevents the next 53-day gap.**

1. **RD2-14 [P0]** Author a new CONTINUATION.md “Session 15” entry summarizing every substantive commit since 646b295 by theme (Cyrillic/UTF-8 fix wave, tracker/plugin fixes, egress/proxy/ Jaxett feature wave, the two governance audits, RD2-00's discovery). Update `**Last commit:**`/`**Last modified:**`/`**Revision:**`.
2. **RD2-15 [P0]** Create tracked workable items (BOB-064..067, via the workable-items tool — never raw MD edits) for the four Lava-porting findings, citing implementing commits as evidence, closed as Implemented.
3. **RD2-16 [P1]** Regenerate docs/browser_extension/Status.md, docs/features/Status.md, docs/codegraph/Status.md + their Status_Summary.md/HTML/PDF siblings (§11.4.45/§11.4.56).

4. **RD2-17 [P1]** Reconcile BOB-008's DB/MD body drift (RD2-04) via the workable-items tool.
5. **RD2-18 [P2]** Create the top-level Boba (proxy/merge-service) v1.0.0 readiness ledger (GA-10) — dedupe with the browser_extension's existing one as the template.
6. **RD2-19 [P2]** Fix BOB-009/BOB-010's evidence_path values + backfill item_history audit trails for the 56 silent closures where recoverable from git log (RD2-03).
7. **RD2-20 [P0]** Wire (or fix) the docs_chain / commit-seam sync hook per §11.4.106(F) so a docs/workable_items.db write can never again land without its MD mirror in the same commit — this is the mechanical fix that prevents Root Cause 2 from recurring, not just a one-time catch-up.
8. **RD2-21 [P1]** Complete/verify the README Tracked-Items + Status Documents table row-completeness (GA-07's remaining half).

Verification: workable-items diff reports zero differences; CONTINUATION.md's Last commit matches actual HEAD; a fresh git log --oneline <last-continuation-commit>..HEAD after this pass returns empty (nothing unreflected).

Root Cause 3 — Two real, unauthenticated mutating HTTP endpoints remain LAN-reachable

Closes: GA-11 (the last remaining piece of RW-02).

1. **RD2-22 [P0, TDD] — SOURCE FIX DONE, LIVE VERIFICATION STILL OWED.** RED: extended tests/security/test_hooks_schedules_auth.py's _MUTATING enumeration to include PATCH /api/v1/schedules/{id} and PUT /api/v1/theme (+ a THEME_STATE_PATH tmp-redirect in the fixture, needed so the theme store's real /config write path didn't mask the auth signal with an unrelated PermissionError — the RED failure had to be re-verified as "wrong status code" not "wrong exception" per TDD discipline). Confirmed 4 clean RED failures (401-expected, got 200) for the right reason. GREEN: added Depends(require_api_token) to scheduler.py's update_schedule and routes.py's put_theme. **Root-cause wrinkle found during GREEN:** require_api_token was defined at routes.py:960, after put_theme — a Depends(...) default-argument is evaluated at function-definition time, so referencing it before its definition raised NameError at import time (crashing every route in the file). Fixed at the root: moved require_api_token's definition to before ThemeUpdate/put_theme (it has no dependencies on anything defined between the old and new location). **Verified GREEN: tests/security/test_hooks_schedules_auth.py 31/31 passed; regression sweep of tests/unit -k "theme or scheduler" 176/176 passed.** Full tests/contract/ + tests/unit/regression sweep in progress. **Still owed:** a live curl-verify on a running container — 401 unauth, 200 with-token — for both

routes (§11.4.108 runtime-signature, source+test-level fix is not yet artifact/runtime-verified) — and the §11.4.135 regression-guard/HelixQA Challenge entry (RD2-23).

2. **RD2-23 [P1]** Regression guard (§11.4.135) + HelixQA Challenge entry for both routes (user-facing mutating surface).

Verification: RED test fails pre-fix, passes post-fix on the exact same assertions (§11.4.115 polarity-switch); live curl output pasted per Definition of Done.

Root Cause 4 — Recently-shipped code has zero test-first coverage (§11.4.224 violations)

Closes: the test-coverage half of GA-27; composes with Root Cause 1's RD2-13.

1. **RD2-24 [P1, TDD]** Author RED-first tests for `start.sh`'s `reload_python()`, `reload_plugins()`, `recreate_stack()` — real executing tests through the actual invocation path (per §11.4.224(A): never a `bash -n` parse-check alone), asserting exit status + the documented side effects (`pycache-clear-then-restart`, `restart-only`, `down-then-up`) against a live or realistically-mocked container runtime.
2. **RD2-25 [P2]** Add a HelixQA Challenge entry exercising all three subcommands end-to-end against the real compose stack.

Verification: tests fail against a stubbed/reverted version of the three functions, pass against current `start.sh` (§11.4.115).

Root Cause 5 — Three test files claim a directory-mandated real-service contract but mock the

system under test; a live skip-fallback masks a drift the constitution forbids masking **Closes: GA-13, GA-14, GA-15, GA-16.**

1. **RD2-26 [P1, parallelizable — 4 independent files]** For each of `tests/integration/test_merge_api.py`, `tests/e2e/test_full_pipeline.py`, `tests/contract/test_tracker_stats_contract.py`: (a) relocate the existing mocked version into `tests/unit/` under an honest name (the coverage is valuable as unit-level route-contract testing — keep it, just where it belongs); (b) author a real-service replacement in the original directory using the repo's existing live-stack fixtures (`tests/fixtures/compose.py`, `tests/fixtures/services.py`, `tests/integration/test_fixtures_bring_up_services.py` already prove this pattern works here).
2. **RD2-27 [P1]** `tests/e2e/test_live_stack_evidence.py:265` — with the live stack up, confirm `curl :7187/api/v1/auth/nmclub/status`

→ 200 (redeploy first if source≠artifact drift persists — see Root Cause 6), remove the skip fallback entirely, let the real assertion run.

Verification: each relocated/replaced file's directory-appropriate real-service test actually issues a real HTTP call to a real running service and asserts on the real response — no @patch/monkeypatch targeting SearchOrchestrator anywhere outside tests/unit/.

Root Cause 6 — Source-layer fixes are unverified/undeployed at the artifact/runtime layer

(§11.4.108 SOURCE≠ARTIFACT/RUNTIME gap), compounding with stress/chaos coverage gaps **Closes: GA-12, GA-20, and the runtime-verification half of RD2-22/RD2-27.**

1. **RD2-28 [P1]** Bring up the live compose stack (./start.sh), run ./install-plugin.sh, verify grep '{0,512}' config/qBittorrent/nova3/engines/rutacker.py on the container, and capture timing of a large rutacker result page (<2s per the original RW-06 acceptance criterion).
2. **RD2-29 [P2, parallelizable]** Author tests/stress/test_tracker_fetch_stress_chaos.py (download-proxy tracker-fetch + cookie-auth path, overlapping the already-fixed SSRF surface) with real §11.4.85 fault injection (process-kill, network-fault, resource-exhaustion — not just concurrency).
3. **RD2-30 [P2, parallelizable]** Author tests/stress/test_scheduler_hooks_sse_stress_chaos.py covering the Go-side internal/service/sse_broker.go + internal/api/hooks.go + internal/api/scheduler_api.go triangle.
4. **RD2-31 [P2]** Extend qBittorrent-go/tests/integration/jackett_db_test.go with real process-kill / resource-exhaustion fault injection (currently concurrency-only).
5. **RD2-32 [P3]** Author DDoS-class coverage (RD2-07) for the exposed download-proxy/merge endpoints.

Verification: each new chaos test is negation-proven (fails without the fault-tolerance code, passes with it), captured evidence per §11.4.5/§11.4.69/§11.4.107.

Ungrouped remaining items (lower priority, independent of the 6 root causes)

1. **RD2-33 [P2] — CLOSED 2026-08-09.** #legacy-untriaged — triage all 14 sites individually (GA-17); for each, determine the real reason, either fix/un-skip or replace the placeholder with a real ticket.
 - **Closed note:** all 14 sites individually read with git log --follow -p / git blame evidence. Root cause traced to one bulk-tagging commit (edd50f8, “fix: revive anilibra tracker,

rewrite for new API” — an otherwise-unrelated commit) that mechanically appended `# SKIP-OK: #legacy-untriaged` to every line containing the substring `pytest.skip`, including docstring prose and comments — a live instance of the §11.4.201(7)(a) carrier-false-positive class. Full per-site table:

#	Site (file:line)	Real reason (evidence)
1	tests/e2e/ test_public_trackers_return_results.py:128	Real <code>@pytest.mark.skipif</code> , already self-documented via <code>reason="Dead trackers are intentionally enabled via ENABLE_DEAD_TRACKERS=1"</code> — intentional feature-flag gate, not a defect (git blame confirms the <code>skipif</code> predates the marker; <code>edd50f8</code> only appended the marker).
2	tests/integration/test_iporrents.py:160	Real <code>pytest.skip</code> , self-documented message "IPTorrents results not in top-N for 'linux'" — live-network tracker ranking is non-deterministic; not a defect (<code>edd50f8</code> diff confirms marker was appended to a pre-existing skip).
3	tests/unit/ test_no_runtime_service_skips.py:4	Not a skip at all. Docstring prose describing the <i>old</i> deprecated pattern this file's fixtures replace (<code>edd50f8</code> diff proves: the marker was appended mid-sentence inside the docstring, a mechanical substring-match error).
4	tests/unit/ test_no_runtime_service_skips.py:10	Not a skip at all. Docstring prose describing this meta-test's own detection regex; same <code>edd50f8</code> mechanical mis-tag.
5	tests/unit/ test_no_runtime_service_skips.py:36	Not a skip at all. A <code>#-comment</code> describing the <code>SKIP_CALL</code> regex definition, not an executed skip; same <code>edd50f8</code> mechanical mis-tag.
6	tests/unit/ test_no_runtime_service_skips.py:84	Not a skip at all. A Python string-literal fixture (line <code>'pytest.skip(...) # allow skip: ...'</code>) used as test Data

#	Site (file:line)	Real reason (evidence)
		for the meta-test's own regex-matching sanity check — not a real, executing <code>pytest.skip</code> call; same edd5 mechanical mis-tag.
7	tests/unit/ test_no_runtime_service_skips.py:94	Not a skip at all. Same class as #6 — a string-literal regex-test fixture, not an executing skip; same edd5 mechanical mis-tag. Real <code>@pytest.mark.skipif, s</code> documented via <code>reason="Frozen OpenAPI spe</code> not found — run <code>scripts/freeze-openapi.sh</code> first"; verified <code>docs/api/openapi.j</code> currently exists so this branch is presently dead (never fires) but is a legitimate generated-artifact guard.
8	tests/unit/test_openapi_frozen.py:15	Real <code>pytest.skip("Cannot import FastAPI app (missing deps)")</code> around a <code>try: from api import app. Live-verified in this session: fails under bare system python3 (ModuleNotFoundError: pydantic_core._pydantic_core succeeds under the project's own .venv/bin/python3 — a genuine, currently-reproducible missing-dependency guard not a defect.</code>
9	tests/unit/test_openapi_frozen.py:23	Real <code>pytest.skip(f"Plugin file not found: {path}")</code> inside <code>_import_plugin</code> . Verified this session: all 1 CANONICAL_PLUGINS files currently exist under <code>plugins/</code> — this branch is presently dead code, a legitimate defensive guard for a future missing plugin file.
10	tests/unit/test_plugin_smoke.py:45	
11	tests/fixtures/services.py:9	Not a skip at all. Inside a module docstring's code-block example (<code>```</code> -fenced

#	Site (file:line)	Real reason (evidence)
		illustrating the <i>old</i>, now-replaced if not <code>requests.get(...).ok:</code> <code>pytest.skip(...)</code> anti-pattern this file's fixtures exist to same <code>edd50f8</code> mechanical mis-tag. Real <code>@pytest.mark.skipif(not _mkdocs_available(), ...)</code> <code>_mkdocs_available()</code> does a real <code>subprocess.run(["mkdocs", version])</code> invocation (<code>\$11.4.201(11)</code> artifact-usability check, not presence-only). Verified <code>mkdocs</code> is installed on this host (<code>mkdocs</code>, version 1.6. so this branch is presently dead; legitimate tool- availability guard.
12	<code>tests/docs/test_mkdocs_builds.py:22</code>	
13	<code>tests/docs/test_mkdocs_builds.py:36</code>	Same function/guard as # (second test in the same f
14	<code>tests/docs/test_no_broken_links.py:51</code>	Real <code>pytest.skip("docs/ directory not found")</code>. Verified <code>docs/</code> exists in this repo — this branch is presently dead code, a legitimate defensive guard

****Summary:** 6/14 were mis-tagged carriers (not real skips)
— fixed by removing the stray marker; 8/14 were genuine,
already-self-documented, intentional/environment-
conditional skips (none were undocumented defects
requiring a new tracked ticket) — the misleading “never
triaged” placeholder was replaced with an honest, specific
SKIP-OK: comment citing the real reason, per this project’s
“skips are loud” convention. No mechanical gate in this
repo currently enforces the SKIP-OK: format (confirmed:
`grep -rln "SKIP-OK" scripts/ constitution/scripts/` finds no
such gate outside Go test fixture files) — the convention is
documentation discipline only, not a build blocker. Zero
#legacy-untriaged occurrences remain in code (`grep -rn
'#legacy-untriaged' . --include '*.py' --include '*.go' --
include '*.sh'` → 0 hits). Verified: all 8 touched Python test
files `py_compile` clean; `test_openapi_frozen.py`,
`test_mkdocs_builds.py`, `test_no_broken_links.py` (all sites in

these 3 files) plus 2 of 3 tests in
test_no_runtime_service_skips.py PASS live under .venv/bin/
python3 -m pytest --import-mode=importlib (278 passed total
in that run). The one pre-existing FAIL in that run
(test_no_runtime_service_skips.py::test_no_runtime_service_skips,
flagging tests/integration/test_merge_api.py:81,90) is
unrelated to this triage — confirmed via git show
HEAD:tests/integration/test_merge_api.py that the flagged
pattern already existed in the committed HEAD before this
session touched anything, and that file was not one of the
14 #legacy-untriated sites.

2. **RD2-34 [P1]** submodules/helixqa/banks/*.yaml — parametrize the 20 hardcoded /Volumes/T7/Projects/Boba/... paths with \$PROJECT_ROOT (GA-23) — lands in the submodule per §11.4.28 decoupling, not boba's own tree.
 3. **RD2-35 [P2] — CLOSED 2026-08-09.** Fix docker-compose.quality.yml's 8/8 missing container-hygiene fields (RD2-02). See RD2-02's Closed note above.
 4. **RD2-36 [P2]** Fix guard-forbidden-commands.sh's substring-match false-positive class (RD2-01) — word-boundary/token-aware matching, not another EXCLUDE_PATHS band-aid; also add the newly-discovered docs/incidents/2026-08-07-const033-poweroff-signal-triage.md carrier to EXCLUDE_PATHS as an immediate stopgap (GA-24's residual).
 5. **RD2-37 [P2] — CLOSED 2026-08-09.** Correct docs/TOKENS_AND_KEYS.md's fictional env vars + add the missing OMDB_API_KEY row (RD2-05). See RD2-05's Closed note above.
 6. **RD2-38 [P2] — CLOSED 2026-08-09.** Replace .trivyignore.yaml's placeholder CVE IDs; author or de-reference the promised test_scan_config.py expiry-enforcement test (RD2-06). See RD2-06's Closed note above.
 7. **RD2-39 [P3]** Bump submodules/jackett one commit (RD2-09).
 8. **GA-19/RW-09 [OPERATOR-DECISION]** Is --profile go parity still a release goal? Gates RW-10..13.
 9. **RW-05 [OPERATOR-DECISION]** LAN-exposure threat model — bind the tunnel 127.0.0.1 or keep 0.0.0.0 with the now-complete auth coverage (post Root Cause 3)?
-

Definition of done for this Round-2 plan

Every RD2-NN item above reaches DONE with **live-captured evidence pasted in the same session as the change** (no self-certification words without it, per this project's own Anti-Bluff Verification mandate), every fix that closes a defect ships a permanent regression guard (§11.4.135) and, where user-facing, a HelixQA Challenge entry, RD2-00's source is identified and resolved, OPERATOR-DECISION items are resolved, docs/GOVERNANCE_AUDIT_2026-08-07.md and docs/REMAINING_WORK_PLAN.md are

marked superseded-by-this-document (§11.4.90 Obsolete, reason superseded-by-later-mandate, never deleted), the full docs/CONTINUATION.md / docs/Issues.md / docs/Fixed.md / docs/workable_items.db chain is back in sync, and a full §11.4.40 retest (pre-build + post-build + live 4-phase cycle + meta-test sweep + Challenge bank + HelixQA autonomous session) passes before any release tag.